



Akrites: The SIRT

Coordinated, confidential vulnerability remediation for the open source software critical infrastructure depends on

Problem Statement

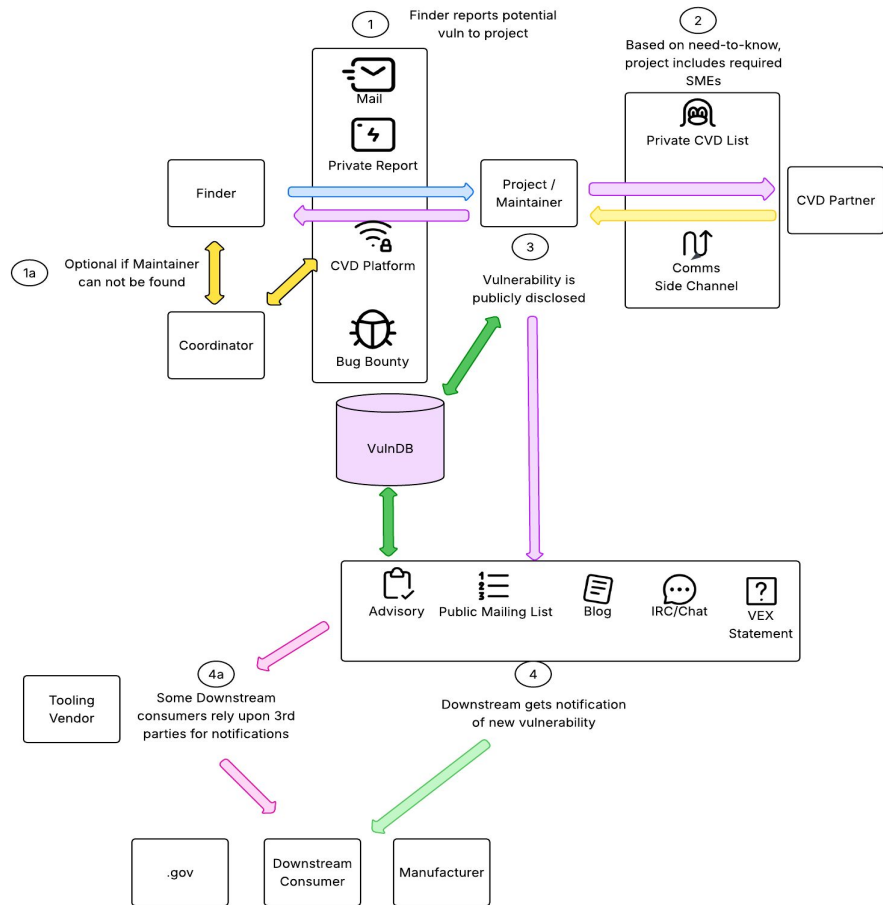
Numerous actors across the ecosystem have access to sophisticated AI tools and are actively scanning open and closed source code bases. There is a potential backlog of hundreds of thousands of reports that need to be properly disclosed.

There is no centralized and neutral party to assist in the coordination of these reports to upstream projects and maintainers.

Akrites is a path forward for the ecosystem to have a neutral broker to assist both up and downstream to address these concerns. The Security Incident Response Team (SIRT) will work with Finders that are using advanced tools and gracefully land those qualified reports with the appropriate parties to disclose publicly.

Introduction

- The ecosystem has come to a crossroads.
- The cost of security research has reduced to such levels that virtually any individual or organization can leverage sophisticated security tooling to discover previously unknown vulnerabilities.
- This SIRT (Open Source Software Security Incident Response Team) will act as a coordinator between external Finders and upstream project security teams and maintainers.



Why "Akrites"

The name comes from the *Akritai*, the Byzantine Empire's frontier guardians, who stood watch where threats arrived first and defenses were thinnest. In modern software, that frontier is upstream: the open source projects everything depends on. Akrites is the industry standing that watch together, alongside the maintainers who have held it alone for too long. Fittingly, the root of the name is the same word that gives us *critical*, which is exactly the software this effort exists to defend.



What is a SIRT?

What is a SIRT?

In a traditional enterprise there are a few teams that “do security”:

CSIRT - Corporate/Computer Incident Response Team - an internal security team focused on users, corporate data, and company infrastructure

PSIRT - Product Security Incident Response Team - a team focused on a company’s product portfolio, helping ensure security practices are followed and vulnerabilities are remediated

CERT or National CSIRT - Computer Emergency Response Team - a coordinator, typically a government-backed entity helping protect a specific sector or national constituency

SIRT - Security Incident Response Team - The SIRT is a team dedicated to helping find, document, disclose, coordinate, and fix security vulnerabilities in open source software; it is neither an internal corporate function nor a product-focused group

Why is an OSS SIRT needed?

Circles of Trust

Complex Stakeholder Landscape

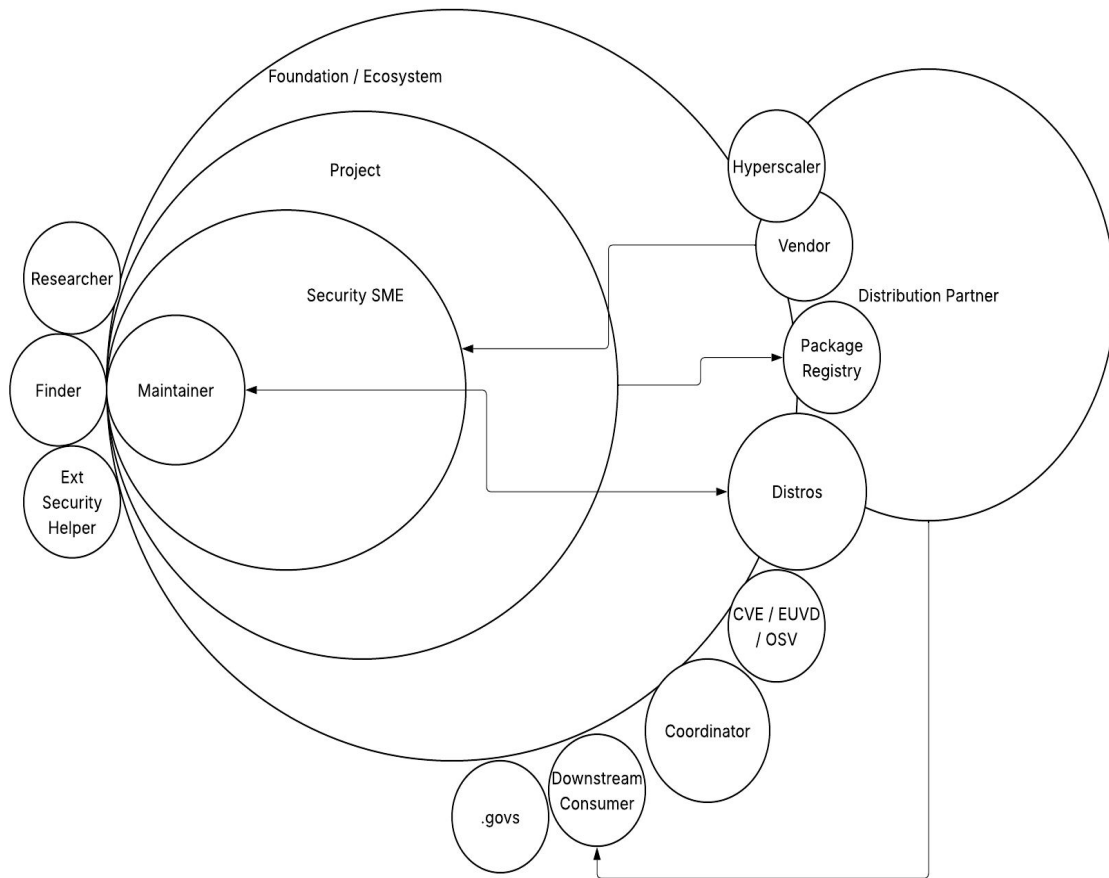
OSS CVD involves numerous unique stakeholders who must be accounted for when revamping security processes.

Intersecting Circles of Trust

These overlapping groups each play a critical role in finding, fixing, and disclosing vulnerabilities.

Diverse Coordination Roles

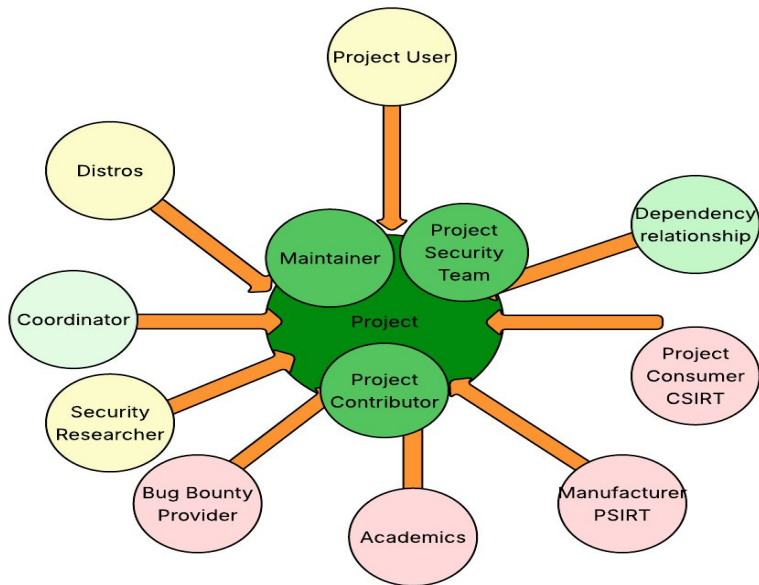
Different stakeholders maintain distinct relationships with the project and have varying roles to play within coordination.



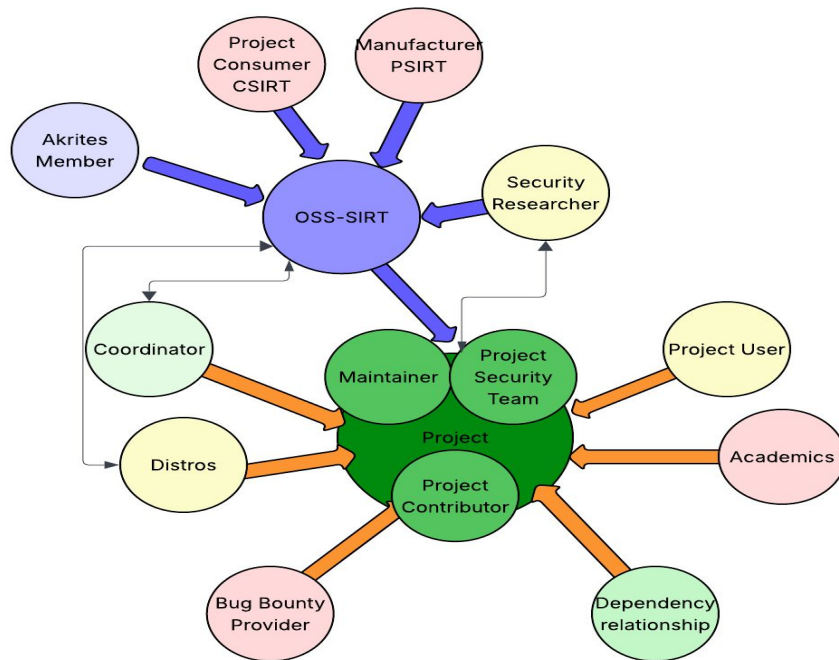
CVD today and CVD tomorrow

Coordination Today

Who finds and reports vulnerabilities?



Coordination with Akrites



The Akrites solution - a shared SIRT

Akrites gives critical infrastructure stakeholders a confidential, structured place to coordinate vulnerability discovery, remediation, and disclosure across the open source projects they depend on, at the pace AI-assisted attackers now operate.

One front door

Upstream maintainers face a coordinated, predictable partner running one standardized CVD process, not a hundred independent reports.

A shared, dedicated SIRT

A centralized Security Incident Response Team validates and deduplicates findings, coordinates resolution and upstream patching.

Leverages industry standards and tools: CVE, TLP, CWE, CVSS, EPSS, SSVC, VEX, OSV, VINCE.

Principles that shape the Akrites

Confidentiality is the first principle

An undisclosed vulnerability in a widely deployed package is, in effect, a weapon. The model is built first to prevent leaks.

Least privilege across the program

Access follows need-to-know, not membership tier. No single party sees the full set of packages critical infrastructure depends on.

Technical contribution is the price of admission

Participants build and ship fixes, or fund the work that does. This is not a pay-to-read service.

One maintainer-facing front door

Fixes are published into the package's original namespace wherever possible, coordinated by the SIRT.

Synchronized disclosure

Upstream maintainers enter the same CVD window at the same moment. No participant gets a head start.

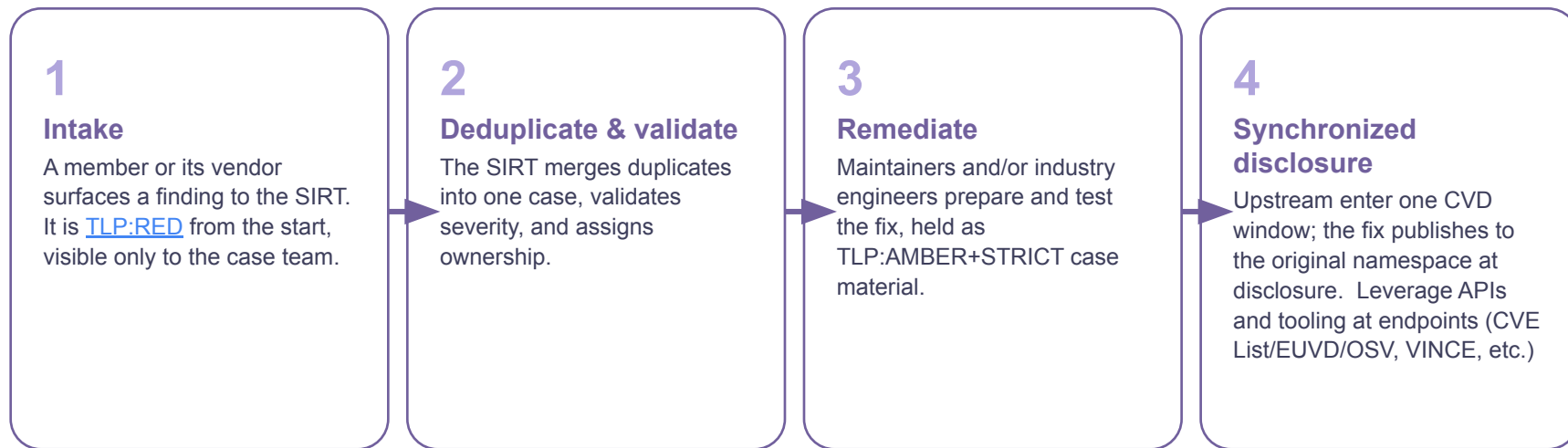
Meet maintainers where they are

Akrites contributes fixes; it does not impose process or tooling. Maintainers keep final authority over their releases.

How the SIRT will function

How a vulnerability flows through the program

Every finding follows the same path so upstream maintainers face one predictable partner and members get consistent embargo handling.



Where no maintainer is responsive, the SIRT may, with TOC approval, publish a time-bounded hardened fork under a reserved namespace. Advisories and CVEs issue through the Linux Foundation's CNA authority.

Confidentiality framework

Critical vulnerability information is protected by use of the TLP 2.0 protocol.

Confidential Hardened Cloud Infrastructure

- Isolated secure enclaves to perform vulnerability analysis, POC/POV verification, and patch creation
- Analyst workbench provided via secure virtual machines
- Protected by strong access controls, MFA, and monitoring
- Access to Vulnerability Reports limited to Finders during triage/verification
- Access to patch bundles limited to Finders and SIRT during Coordination & Disclosure
- TLP gatekeeps access along all phases of engagement

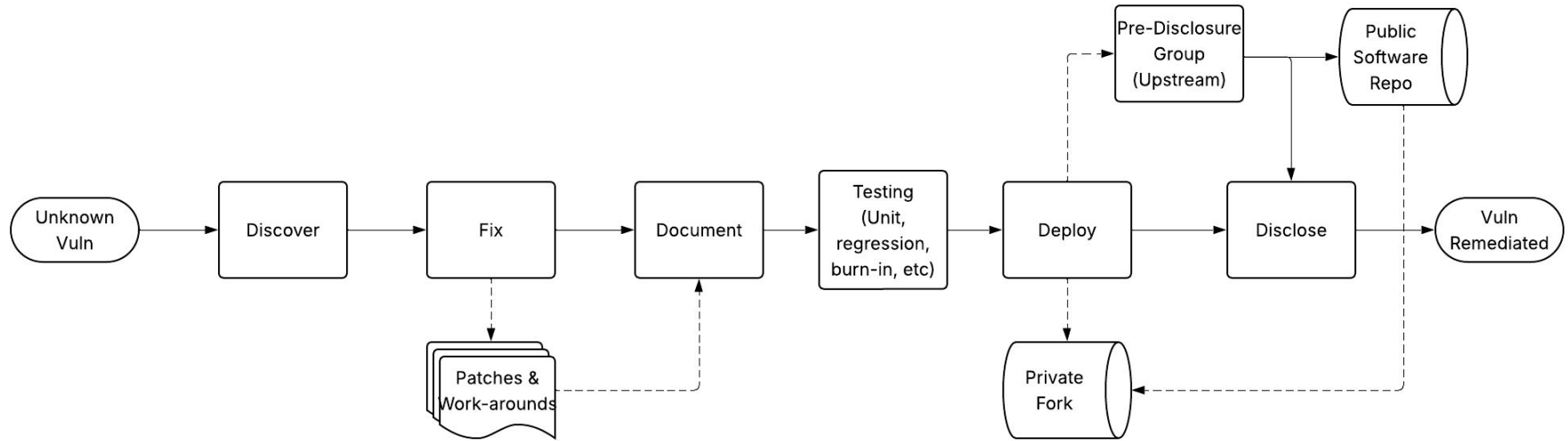
A shared, dedicated SIRT

- A centralized Security Incident Response Team validates and deduplicates findings, coordinates resolution and upstream patching.
- Leverages industry standards and tools: CVE, TLP, CWE, CVSS, EPSS, SSVC, VEX, VINCE, OSV.

Confidential Coordination

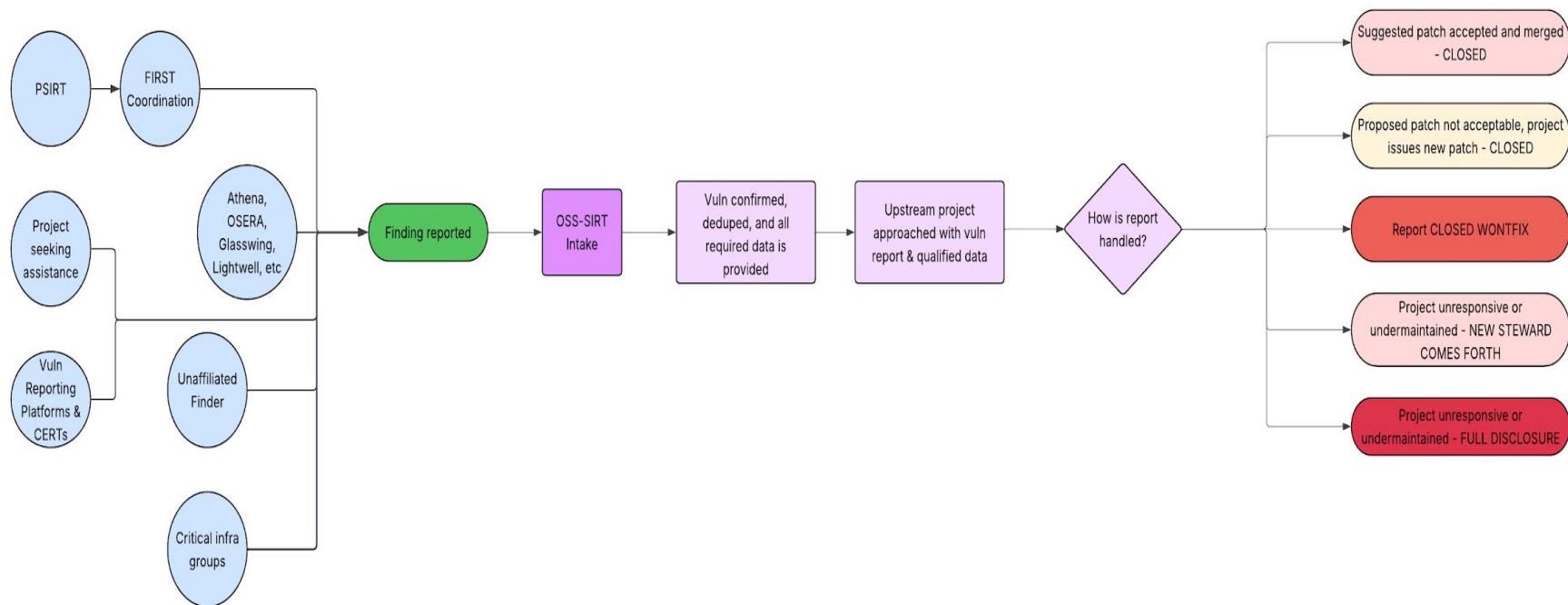
- CVD Tools like VINCE used to assist in coordination/case management
- TLP covers all parties and artifacts until PD
- Confidential reporting tools used to report issues upstream (e.g. GitHub Private Reporting)

High Level LLM-powered CVD



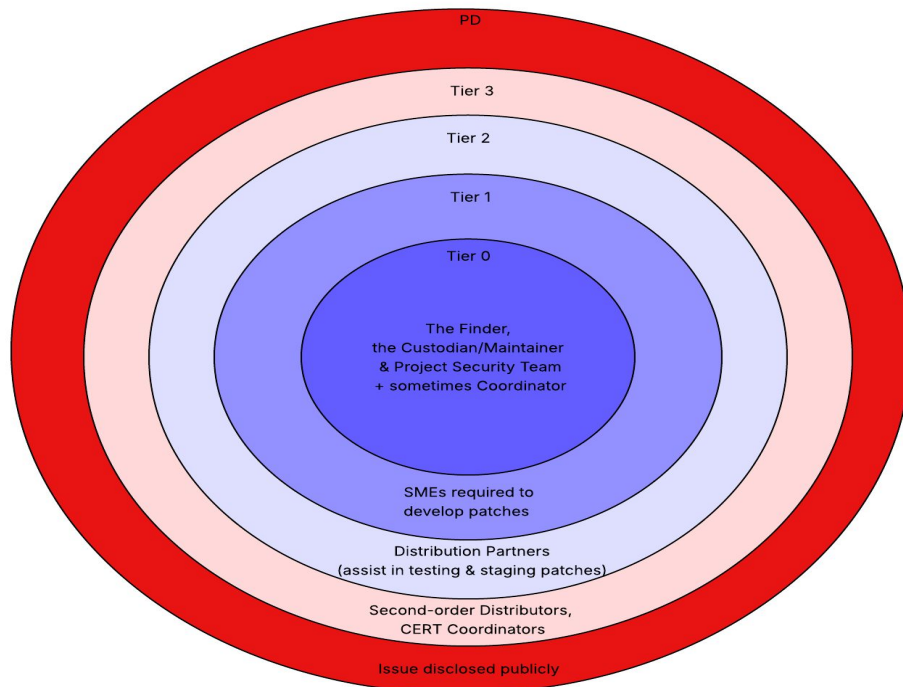
This proposal assumes that groups of Finders are using LLMs to discover previously undisclosed vulnerabilities and seek to get those fixes shared with upstream maintainers

OSS-SIRT Intake Process (simple)



Tiered Disclosure

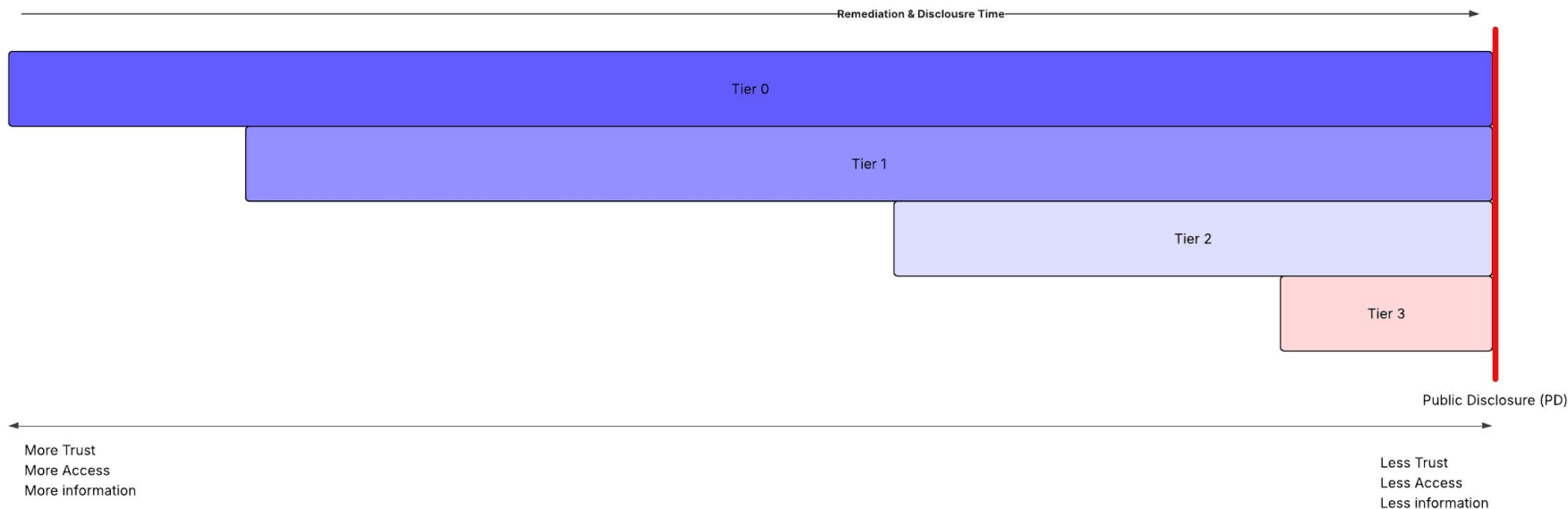
For complex projects, Tiered Disclosure reads in additional stakeholders with specialized expertise. This ensures all users gain equal, timely access to fixes and documentation upon public disclosure to protect their systems.



Tier Zero	Maintainer/Project Security Team + Finder	*Coordinator
Tier One	Tier 0 + required SMEs to develop patch	
Tier Two	Tier 0 & 1 + Distribution partners/Distros	
Tier Three	Tier 0-2 + 2nd order distributors + CERT Coordinators	
Public Disclosure (PD)		

This is a general tiered disclosure model. Not every project or community operates this way (some may skip phases or perhaps have even more stages in their deployments)

Typical Tiered Disclosure phase example



In Tiered Disclosure, as an incident is being worked, external parties are brought in for their subject matter expertise and ability to help develop & test fixes or deploy patches once they are available

Roles & Responsibilities

OSS-SIRT

- Responsible for operations of the SIRT
- Manages intake & deduplication of findings
- Coordinates with appropriate parties to disclose confirmed vulnerabilities
- Assists in public communications at Public Disclosure (PD) as needed

Maintainer/Project/Security Team

- Develops, maintains, or is security SME for project
- Reviews & confirms/refutes reported findings
- Accepts or creates patch for confirmed findings
- Owns public messaging around PD for project

Manufacturer PSIRT

- Has tools, infra, or expertise needed for disclosure
- Provides project as component of product, therefore needs to know when new vulnerabilities are disclosed

Finder

- Discovers potential vulnerability and reports
- Can confirm remediations/patches versus research
- At PD typically delivers detailed technical analysis of issue & response

Coordinators

- At PD ensures constituents are informed of vulnerability and response

Akrites SIRT Q&A

QUESTION

What is OSS-SIRT and what problem does it solve?

ANSWER

OSS-SIRT (Open Source Security Incident Response Team) is a Linux Foundation coordinated vulnerability response function designed specifically for the open source ecosystem, rather than any single vendor.

The Problem: Upstream vulnerability findings are surging due to AI scanning tools, but most maintainers lack the specialized security expertise, bandwidth, or tools to coordinate disclosures safely.

The Solution: OSS-SIRT bridges this gap as a trusted partner. It manages intake, triage, validation, and patch coordination to ensure fixes reach upstream sources and downstream consumers responsibly.

QUESTION

How does Akrites relate to or integrate with other industry efforts?

ANSWER

Complementary Integration: Operates within CVD frameworks (FIRST, ISO, CERT/CC) to feed standard artifacts (CVE, OSV, VEX) into databases like CVE/NVD and EUVD.

Maintainer-First Focus: Acts as a coordinator for upstream OSS projects lacking dedicated security teams, private channels, or bandwidth for multi-party disclosures.

Unified Ingestion: Works with PSIRTs, bug bounty platforms, and FIRST members as referral partners to ensure consistent, reliable handling across all channels.

QUESTION

What does a typical finding lifecycle look like once it enters OSS-SIRT?

ANSWER

- 1. Discovery & Intake:** Ingests reports from scanners, researchers, or bug bounties, auditing them for completeness and deduplication.
- 2. Triage & Validation:** Reproduces the issue, determines CVSS severity, classifies root causes, and checks for active exploitation.
- 3. Patch & Testing:** Collaborates with finders and SMEs to develop and validate a "SIRT-ready" fix containing a patch and unit tests.
- 4. Document & Disclosure:** Coordinates upstream release dates, manages downstream notifications, and publishes CVE/OSV advisories.

QUESTION

How does OSS-SIRT support downstream consumers (distros, package registries, manufacturers, and enterprises) not just the upstream project?

ANSWER

Tiered Disclosure: Coordinates early, scheduled sharing with distros, registries, PSIRTs, and critical infrastructure partners before public release.

Automated Pipelines: Publishes machine-readable artifacts (OSV, CVSS, VEX) to OSV, which auto-routes data directly to CVE and EU SRP.

Frictionless Remediation: Integrates with downstream scanners and SBOM systems to surface actionable, pre-attached remediation advice.

QUESTION

How should an upstream maintainer or project security team expect OSS-SIRT to interact with them and will it feel like an intrusion or an unwanted takeover?

ANSWER

Opt-In Partnership: Designed as a collaborative partner, not an authority. OSS-SIRT delivers fully qualified bundles (vulnerability details, working PoC, proposed patch, and tests) so maintainers review solutions rather than solve problems cold.

Maintainer Control: Upstream teams retain complete authority. You approve/revise patches, set or negotiate disclosure timelines, and receive full credit for all public disclosures.

Overhead Reduction: OSS-SIRT manages time-consuming coordination like CVE registration, advisory drafting, and stakeholder outreach. If you have an established security process, OSS-SIRT can simply step back to a supporting role.

Patch the commons, together.

Join critical infrastructure operators and their vendors in building a confidential, coordinated defense for the open source software we all rely on.

Terms

Glossary of Terms

CVD - Coordinated Vulnerability Disclosure - <https://www.first.org/global/sigs/vulnerability-coordination/multiparty/guidelines-v1.1>

CVE - Common Vulnerabilities & Exposures - <https://www.cve.org/About/Overview>

CVSS - Common Vulnerability Scoring System - <https://www.first.org/cvss/>

CWE - Common Weakness Enumeration - <https://cwe.mitre.org/>

EPSS - Exploit Prediction Scoring System - <https://www.first.org/epss/>

EUVD - European Vulnerability Database - <https://euvd.enisa.europa.eu/>

FIRST - Forum of Incident Response and Security Teams - www.first.org

IR - Incident Response

NVD - National Vulnerability Database - <https://nvd.nist.gov/>

OSS - Open Source Software

OSV - Open Source Vulnerability (database) - <https://osv.dev/>

PD - Public Disclosure

POC - Proof of Concept

POV - Proof of Vulnerability

SME - Subject Matter Expert -

SIRT - Security Incident Response Team - [FIRST Security Team Definitions](#)

SSVC - Stakeholder Specific Vulnerability Categorization - <https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc>

TLP - Traffic Light Protocol - <https://www.first.org/tlp/>

VDP - Vulnerability Disclosure Program

VDR - Vulnerability Disclosure Report

VM - Vulnerability Management

Legal Notice

Copyright © Akrites®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners. Per the Akrites Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share: copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt: remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution: You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions: You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.